

Student Assignment Brief

CONFIDENTIAL DOCUMENT

This document is intended solely for Softwarica College of IT & E-Commerce students for their own use in completing their assessed work for this module. It must not be passed to third parties or posted on any website.

Contents

- Assignment Information
- Assessed Module Learning Outcomes
- Assignment Task
- Marking and Feedback
- Assignment Support and Academic Integrity
- Assessment Marking Criteria

Assignment Information

Module Name:	Security
Module Code:	ST6005CEM
Assignment Title:	ST6005CEM Security March Intake 2026 Coursework CW2 (Regular)
Assignment Due:	Jul 31, 2026

Assignment Credit:	10
Word Count:	2000
Assignment Type:	Coursework : Individual Report
Grading:	Percentage Grade(Applied Core Assessment).

Assessment Overview

You will be provided with an overall grade between 0% and 100%. You have one opportunity to pass the assignment at or above 40%.

Important Notice

The work you submit for this assignment must be your **own independent work**. More information is available in the 'Assignment Task' section of this assignment brief.

Assessed Module Learning Outcomes

The Learning Outcomes for this module align with the marking criteria which can be found at the end of this brief. Ensure you understand the marking criteria to ensure successful achievement of the assessment task. The following module learning outcomes are assessed in this task

Critically evaluate a range of encryption and authentication methods for a given set of requirements.

Utilise systematic knowledge to create secure environments at the host or network level.

Develop and evaluate software that addresses the most common and most severe security concerns.

Critically evaluate the security of an IT ecosystem.

Assignment Task

You are required to design, develop, secure, and internally penetration test a custom-built web application that addresses a clearly defined user need and is original in both concept and implementation. The objective of this coursework

is not only to build a functional application but to demonstrate secure-by-design thinking, correct security implementation, and a professional internal security evaluation of your system, bridging theoretical knowledge with practical skills and emerging cybersecurity threats.

The use of premade templates, boilerplate security frameworks without understanding, or AI-generated application logic is strictly discouraged, as these commonly introduce undocumented business logic flaws. Evidence of such usage may result in penalties. Students must demonstrate ethical hacking practices and compliance with legal standards during testing, and failure to meet these requirements may result in mark deductions or rejection of the submission.

1. Web Application Overview

This section must describe the application and the user problem it addresses.

1. Clear definition of the problem or user need addressed by the application
2. Justification of why the application is necessary and how users benefit from it
3. Explanation of the uniqueness and meaningfulness of the application concept
4. Discussion of emerging technologies or sustainable practices where applicable

2. Core Functional Features

This section must describe the core functionality of the application from a user and security perspective.

1. Design of an intuitive and accessible user interface
2. Ease of navigation and usability for all user roles
3. Accessibility considerations, testing approach, and findings

User registration and authentication must be securely implemented and explained.

1. Secure user registration and login implementation
2. Multi-Factor Authentication support
3. Brute-force protection mechanisms including rate limiting, account lockout, and CAPTCHA
4. Custom authentication logic aligned with zero-trust principles

Customizable user profiles must be implemented securely.

1. Secure profile personalisation aligned with application purpose
2. Protection against IDOR, mass assignment, and privilege escalation
3. Secure handling of profile data
4. Data export and import features aligned with privacy principles

Secure transaction processing must be implemented where applicable.

1. Use of trusted third-party services or a justified custom solution
2. Protection of transaction integrity and confidentiality
3. Proper error handling and rollback mechanisms
4. Consideration of supply chain risks for third-party APIs

Activity logging and monitoring must be implemented.

1. Meaningful user activity logging
2. Support for auditing, incident response, and security review
3. Avoidance of sensitive data exposure in logs
4. Real-time monitoring and alerting where applicable

3. Security Features

This section must describe the security mechanisms implemented in the application.

1. Robust password policy including length, complexity, reuse prevention, expiry, and strength feedback
2. Consideration of password-less authentication as an advanced feature

System-wide brute-force protection must be enforced.

1. Rate limiting and request throttling
2. IP-based blocking and allow-listing
3. Consistent application across authentication and sensitive endpoints

Role-Based Access Control must be implemented.

1. Least-privilege access design
2. Enforcement of access restrictions across the application
3. Demonstration and testing of access control logic, including APIs

Secure session management must be implemented.

1. Secure cookie attributes
2. Session expiration and invalidation
3. Protection against session-related attacks
4. Optional session binding to user agents or devices

Encryption and data protection must be enforced.

1. Secure password hashing
2. Encryption of sensitive data where required
3. Justification of encryption choices and key management practices

4. Secure Development and Internal Penetration Testing

This section must demonstrate secure development practices and professional internal testing.

1. Source code hosted on GitHub
2. Minimum of forty meaningful commits
3. Evidence of incremental security improvements
4. Vulnerability fixes reflected in commit history
5. Use of containerization for reproducible environments
6. CI/CD pipelines with automated security checks

A formal internal penetration test must be conducted.

1. Defined scope, assumptions, and ethical guidelines
2. Use of recognised testing methodologies
3. Manual testing as the primary approach
4. Supplementary use of automated tools
5. White-box testing through source code review and targeted fuzzing
6. Coverage of authentication, authorization, business logic, input validation, session handling, client-side vulnerabilities, and API security

All vulnerabilities must be fully documented.

1. Vulnerability name, category, and CVSS v3.1 rating
2. Technical explanation and exploitation path
3. Supporting evidence including screenshots, payloads, and code snippets
4. Remediation steps, fix confirmation, and retesting evidence

5. Proof of Concept Video Demonstration

A video demonstration is compulsory and must clearly show the implemented security features and vulnerabilities.

1. Closed captions enabled with editor permission to the Google Drive
2. Demonstration of security controls
3. At least two realistic vulnerability scenarios shown before and after fixes
4. Explanation of discovery methods, root causes, and mitigations
5. Clear visibility of the student's face
6. Clear and uninterrupted audio

6. Report Structure

The submitted report must follow a formal academic structure.

1. Cover page

2. Abstract
3. Table of contents
4. Table of figures
5. Table of abbreviations
6. Introduction
7. Software details
8. Design and implementation
9. Secure development and penetration testing
10. Proof of concept
11. Conclusion
12. References

The design and implementation section must demonstrate depth and technical clarity.

1. System architecture and component interactions
2. Security-by-design decisions and threat modeling
3. Analysis of security risks and mitigations
4. Code-level examples of security mechanisms
5. Mapping of GitHub commits to security decisions
6. Discussion of integrated emerging technologies

7. References

A minimum of fifteen academic or professional references must be included.

1. Books
2. Research papers
3. Security standards
4. OWASP documentation
5. Vendor and professional security resources

Proper in-text citations are mandatory using CU Harvard or CU APA style.

8. Evidence Quality Requirements

All submitted evidence must meet quality standards.

1. Screenshots must be clear and readable
2. Evidence must demonstrate deterministic and repeatable behaviour

9. Enforcement Notice

Failure to comply with requirements related to secure development, internal penetration testing, evidence quality, documentation standards, or academic integrity may result in penalties.

1. Mark deductions
2. Section invalidation
3. Rejection of the entire submission in severe cases

Submission Instructions

Requirement	Details
File Naming	NAME_studentID
File Format	.docx/.pdf format
Submission Method	Campus 4.0 platform (submission link provided 2 weeks before deadline)

Marking and Feedback

How will my assignment be marked?

Your assignment will be marked by the Module Team using standardized criteria.

How will I receive grades and feedback?

Provisional marks will be released once internally moderated. Feedback will be provided alongside grades release within 2 weeks (10 working days).

What will I be marked against?

Details of the marking criteria for this task can be found in the Assessment Marking Criteria section at the end of this brief.

Grade Requirements

You must achieve 40% or above to pass this assessment. Ensure you understand the marking criteria for successful completion.

Assignment Support and Academic Integrity

Getting Help

If you have any questions about this assignment, please meet your respective module leader or teacher for more information.

Language Standards

You are expected to use effective, accurate, and appropriate language within this assessment task.

Academic Integrity

The work you submit must be your own. All sources of information need to be acknowledged and attributed; therefore, you must provide references for all sources of information and acknowledge any tools used in the production of your work, **excluding Artificial Intelligence (AI)**.

We use detection software and make routine checks for evidence of academic misconduct. Definitions of academic misconduct, including plagiarism, self-plagiarism, and collusion can be found in Student handbook in Campus 4.0.

All cases of suspected academic misconduct are referred to for investigation, the outcomes of which can have profound consequences to your studies.

Support for Students with Disabilities

If you have a disability, long-term health condition, specific learning difference, mental health diagnosis or symptoms, contact the Student Support Office for assistance.

Unable to Submit on Time?

If events prevent you from submitting on time, guidance on extenuating circumstances is available in the Student Handbook or from the Student Support Office.

Administration of Assessment

Module Leader Name:

—

Module Leader Email:

—

Attempt Type:	regular
Component Code:	cw2

Assessment Marking Criteria

Criterion	0–39	40–49	50–59	60–69	70+
Alignment with Task Objectives Functional Features	The application does not meet the basic objectives of the task, showing major omissions in required features such as secure user registration, brute-force prevention, or privacy controls. Core functionality is absent or non-operational, with no evidence of addressing the defined user need.	The application addresses some parts of the task, but there are significant gaps in essential features like user-centric design or transaction processing. Functionality is partial and unreliable, with weak justification for the application's purpose.	The application meets most task objectives, with core functionality included, but some features such as customisable profiles or activity logging are underdeveloped or inconsistently implemented. User need is addressed at a basic level.	The application effectively meets the task's objectives, incorporating key features such as secure registration, privacy controls, and secure transaction processing. Functionality is reliable and aligned with the user need, with good integration of mandatory elements.	The web application is highly aligned with the task objectives and demonstrates attention to complex mechanisms. All major/minor functional features are implemented and extended with user-centric design, robust workflows, and innovative elements beyond the baseline.
Report Structure Analytical Depth	The work is mostly descriptive with no critical analysis, and the argument lacks logical structure or coherence. Required sections are missing or irrelevant, making the report disorganized and difficult to follow.	The structure of the report is weak, relying heavily on descriptions without meaningful analysis. The argument lacks clarity and fails to clearly link features with their purpose. Sections are present but inconsistently connected.	The report presents a generally clear argument but may be overly descriptive and not consistently analytical. Structure is logical but limited in depth, with adequate but basic cohesion between sections.	The report presents a well-structured argument with evaluative discussion, although some aspects may lack depth. Sections flow logically, with good critical evaluation and connections between design, implementation, and security decisions.	The report is logically structured and demonstrates in-depth critical analysis with original insights and well-articulated connections between features. Presentation is professional, coherent, and examiner-ready, with strong analytical depth throughout.
Security Features Implementation	Core security features like MFA, RBAC, encryption, or session management are either completely missing or improperly implemented. No evidence of secure-by-design thinking or protections against common threats.	Implemented security measures may be incomplete or non-functional, with significant gaps in essential measures like access control or encryption. Basic attempts are present but lack correctness or justification.	Security features like MFA, RBAC, and encryption are implemented at a basic level, though some elements such as brute-force prevention or proper session handling are underdeveloped. Functionality is present but not robust.	Core security measures including MFA, encryption, RBAC, and session management are present and mostly well-implemented. Features are justified and demonstrate understanding of threats, with good integration across the application.	The implementation includes strong measures like MFA, RBAC, encryption, secure sessions, and password policies, extended with advanced elements like zero-trust principles or emerging threat protections. Demonstrates sophisticated secure-by-design thinking and defense-in-depth.
Testing, Auditing,- Vulnerability Management	There is no evidence of testing, auditing, or understanding of system vulnerabilities. Internal penetration testing is absent, with no	Evidence of testing or internal review is minimal or superficial. Vulnerabilities are not adequately identified or	Testing or auditing may be incomplete or lack depth, but basic evidence is present. Vulnerabilities are noted at a surface level, with	There is good evidence of testing, auditing, and attention to vulnerabilities, even if not exhaustive. Internal penetration testing covers key areas, with	Supported by extensive testing, internal audits, and penetration testing. Vulnerabilities are exhaustively identified, analyzed, and fixed,

	documentation of issues or fixes.	addressed, with little to no auditing or remediation.	partial documentation and fixes.	documented issues, PoCs, and remediations.	with high-quality evidence, hypothesis-driven methods, and clear mapping to secure development practices.
Research, Referencing,- Understanding of Security Concepts	Minimal or no research is present, and referencing is either missing or incorrect. The submission reflects a poor grasp of fundamental security concepts.	Research is sparse, and few (if any) additional security features are implemented. Referencing is inconsistent, and the report demonstrates a limited understanding of security principles.	Research is evident but limited, and the inclusion of additional features is minimal. Referencing is present but may contain errors. The overall understanding of security concepts is basic but functional.	Research is relevant and leads to some additional security feature implementation. Referencing is mostly correct with minor issues, reflecting a solid understanding of security principles.	Research goes beyond the baseline and leads to well-justified additional security implementations. All references are accurate, and the work reflects a sophisticated understanding of modern application security practices.

Softwarica College of IT & E-Commerce | In collaboration with **Coventry University**

This document is confidential and intended solely for enrolled students.